

Lab 06 – Real CVE Walk-Through – Solutions

Industrial Security (Bachelor) • Maps to Section 06 • 45 min

LAB 06

🎯 Goal

Lecturer / TA reference for Lab 06: a fully worked CISA advisory decomposition, an environmental-CVSS re-scoring example, the annotated safe-nmap profile against the lab PLC, the survival check, and a grading rubric.

✅ Part 1, Steps 1–2 – worked advisory: ICSA-22-102-02

Reference advisory: **ICSA-22-102-02**, *Rockwell Automation Logix Controllers*, originally published **12 April 2022** by CISA. Use this as the canonical worked example; any current advisory of comparable depth is acceptable from a student.

Field	Value
ICSA ID	ICSA-22-102-02
Publish date	12 Apr 2022 (updated thereafter by CISA)
Vendor	Rockwell Automation
Affected products	Logix Designer (Studio 5000) + ControlLogix 5570/5580, CompactLogix 5370/5380/5480, GuardLogix 5570/5580, Compact GuardLogix 5370/5380
Affected firmware	Controllers running affected versions prior to the fixed firmware listed by the vendor PSIRT (see Rockwell PN1645)
CVE ID	CVE-2022-1161 (controller side; companion CVE-2022-1159 covers the Studio 5000 side)
CVSS v3.1 base score	10.0 (Critical)
CVSS v3.1 vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
CWE	CWE-20 Improper Input Validation (“forged logic download” – user-readable logic differs from logic actually executed)
Pre-conditions	Network reachability of the controller’s EtherNet/IP service (TCP/UDP 44818, TCP 2222); no authentication required if the controller is not in <i>Run-mode key</i> hardware lock; no user interaction
Stated impact	Attacker can write modified ladder/structured-text logic to the controller while the engineering workstation continues to display the original program – a stealthy logic-tamper primitive
Known exploitation	Proof-of-concept disclosed by Claroty (Team82); no confirmed in-the-wild abuse at publish date
Vendor mitigation	Apply fixed firmware per Rockwell PSIRT advisory PN1645; set the controller mode switch to RUN (hardware key) to block remote program downloads
CISA mitigation	Minimise network exposure (controllers not Internet-facing), place behind firewalls, isolate from business network, use secure remote access (VPN) and update the VPN, perform impact analysis before deploying

Sources: CISA, *ICSA-22-102-02 Rockwell Automation Logix Controllers*, 12 Apr 2022 | Rockwell PSIRT PN1645, 2022 | Claroty Team82, *Evil PLC & Forged Logic Download*, 2022.

✅ Part 1, Step 3 – environmental re-scoring (PLC behind a data diode)

Same controller, deployed in a small water utility behind a hardware one-way data diode (process LAN → historian only; no inbound path):

- **MAV:A** – Modified Attack Vector *Adjacent*. The diode breaks routed L3 reachability; only an attacker already on the local OT segment can talk EtherNet/IP to the controller.
- **MAC:H** – Modified Attack Complexity *High*. The attacker must first defeat physical/network access controls (cabinet lock, managed switch, 802.1X) to land on that segment.
- **MPR:N** – no authentication on the protocol itself, unchanged.

- MUI:N – no user interaction needed, unchanged.
- MS:U – Modified Scope *Unchanged*. The diode prevents the compromised controller from being used as a pivot back into IT; the blast radius stops at the OT cell.
- MC:H / MI:H / MA:H – once on-segment, impact on the process is still total.
- Environmental requirements (utility is safety-relevant): CR:H, IR:H, AR:H.

Modified vector:

```
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H/
MAV:A/MAC:H/MS:U/CR:H/IR:H/AR:H
```

Environmental score drops from **10.0 Critical** to roughly **7.0–7.5 High** (exact value depends on the calculator; accept anything in the **6.8–7.6** band with the justifications above). Teaching point: the vulnerability is just as dangerous *if* the attacker gets on-segment – the diode bought *exposure* reduction, not *impact* reduction.

✓ Part 2 – safe nmap against the lab PLC

Exact command students run inside the student container:

```
1 $ docker compose exec student \
2   nmap -sT -Pn -n --max-rate 5 --scan-delay 200ms \
3   -p 502,8080 172.28.0.10
```

Flag-by-flag justification:

- -sT – full TCP connect via the OS stack, *not* raw SYN. Fragile PLC TCP stacks (legacy Schneider, older Siemens S7) have crashed on half-open SYN floods; a clean 3-way handshake plus RST is the safest probe.
- -Pn – skip host discovery. Many PLCs and ICS gateways drop or rate-limit ICMP; without -Pn nmap would mark the target “down” and never scan it.
- -n – no DNS resolution. Avoids leaking the target IP to a DNS resolver and removes a source of timing jitter.
- -max-rate 5 – cap at 5 packets per second. Well below any documented denial-of-service threshold for ICS devices.
- -scan-delay 200ms – force at least 200 ms between probes. Belt-and-braces with -max-rate; the two together guarantee a gentle scan even if nmap recalculates timing.
- -p 502,8080 – only the two ports the lab actually uses (Modbus/TCP and the OpenPLC web UI). No port sweep, no UDP, no fingerprinting probes.

Expected output (abridged):

```
1 Starting Nmap 7.94 ( https://nmap.org ) at 2026-... CET
2 Nmap scan report for 172.28.0.10
3 Host is up (0.00050s latency).
4
5 PORT      STATE SERVICE
6 502/tcp    open  mbap
7 8080/tcp    open  http-proxy
8
9 Nmap done: 1 IP address (1 host up, 2 ports scanned) in ~1.6s
```

✓ Part 2 – forbidden flags and why

Do **not** run any of the following against a real PLC (or this lab, which mimics one):

- -sV (version detection) – sends protocol-specific probes (NULL, Modbus malformed PDUs, HTTP OPTIONS, etc.). Documented to lock ladder-logic memory regions on several controllers and to crash older Schneider Modicon Quantum CPUs during banner grabs.
- -O (OS fingerprint) – sends crafted TCP/IP packets (out-of-order flags, weird window sizes). Legacy ICS TCP stacks have rebooted under -O.

- **-script / -sC** – NSE scripts vary wildly in safety; **modbus-discover**, **s7-info**, etc. have all triggered comms faults on production PLCs.
- **-A** – shorthand for **-O -sV -sC -traceroute**: combines everything above. **Never** use it on OT.

Sources: Digital Bond / Project Basecamp, *ICS Device Failure Modes During Active Scanning*, 2012 | ICS-CERT, *Recommended Practice: Updating Antivirus in an Industrial Control System*, 2011 – both document the historical fragility.

✓ Part 2 – post-scan survival check

After the nmap run, the student must re-run the Lab 02 read script:

```
1 $ docker compose exec student python3 /labs/scripts/modbus_read.py
2 Registers 0..9: [0, 0, 0, 0, 0, 0, 0, 0, 0, 0]
```

A successful read of **exactly 10 registers** proves the Modbus/TCP server is still responsive and the IEC task is still cycling. If the script throws **ConnectionRefusedError** or hangs past 5s, the PLC stack did not survive the scan – collect the nmap command actually issued, the container logs (`docker compose logs openplc`), and stop further scanning until the runtime is restarted.

✓ Common student mistakes

- **nmap -sS** – raw SYN scan; needs **root/CAP_NET_RAW** in the container and is exactly the half-open behaviour that has crashed legacy PLC stacks. Mark down even though the lab container “survives” it.
- **Default scan with no rate cap** – `nmap 172.28.0.10` alone fires ~1000 probes at line rate; cite that pps figure when grading.
- **Wrong target IP** – scanning 127.0.0.1 from inside **is-student** hits the student container, not OpenPLC. Correct target is 172.28.0.10.
- **-A aggressive scan** – collects everything (**-O -sV -sC -traceroute**). Auto-fail this part.
- **Skipping the survival check** – nmap completing successfully is not evidence the PLC is healthy; only the follow-up `modbus_read.py` is.
- **Citing the wrong vendor advisory** – students sometimes paraphrase a news article instead of the CISA ICSA page; require the ICSA-YY-NNN-NN identifier and the vendor PSIRT number.

📊 Grading rubric

- **3 pts** – advisory decomposition complete: ICSA ID, vendor, affected models + firmware band, CVE ID(s), CVSS v3.1 vector *and* score, CWE, vendor mitigation, CISA mitigation.
- **2 pts** – environmental re-score: at least MAV, MAC, MS modifiers justified in writing; numerical result within ± 0.5 of the worked answer.
- **2 pts** – safe-nmap command run exactly as specified (**-sT -Pn -n -max-rate 5 -scan-delay 200ms -p 502,8080**) against 172.28.0.10; output captured.
- **1 pt** – post-scan `modbus_read.py` returns the expected 10-register vector.
- **2 pts** – short written paragraph (3–5 sentences) on *why* **-sV**, **-O**, **-A**, **-script** are unsafe against real PLCs, with at least one concrete vendor/incident reference.

Total: **10 pts**. Auto-deduct 2 pts for any forbidden flag in the submitted command history; auto-fail (0 pts on Part 2) if the student scanned an IP outside the lab subnet 172.28.0.0/24.